

information at or by a business associate of a covered entity, the Act requires the business associate to notify the covered entity of the breach. Finally, the Act requires the Secretary to post on an HHS Web site a list of covered entities that experience breaches of unsecured protected health information involving more than 500 individuals.

Section 13400(1) of the Act defines “breach” to mean, generally, the unauthorized acquisition, access, use, or disclosure of protected health information which compromises the security or privacy of such information. The Act includes three exceptions to this definition to encompass situations Congress clearly intended not to constitute breaches: (1) Unintentional acquisition, access, or use of protected health information by an employee or other person acting under the authority of a covered entity or business associate if such acquisition, access, or use was made in good faith and within the course and scope of the employment or other professional relationship of such person with the covered entity or business associate and such information is not further acquired, accessed, used, or disclosed by any person (section 13400(1)(B)(i)); (2) inadvertent disclosure of protected health information from one person authorized to access protected health information at a facility operated by a covered entity or business associate to another person similarly situated at the same facility and the information received is not further acquired, accessed, used or disclosed without authorization by any person (section 13400(1)(B)(ii) and (iii)); and (3) unauthorized disclosures in which an unauthorized person to whom protected health information is disclosed would not reasonably have been able to retain the information (section 13400(1)(A)).

Further, section 13402(h) of the Act defines “unsecured protected health information” as “protected health information that is not secured through the use of a technology or methodology specified by the Secretary in guidance” and provides that the guidance specify the technologies and methodologies that render protected health information unusable, unreadable, or indecipherable to unauthorized individuals. Covered entities and business associates that implement the specified technologies and methodologies with respect to protected health information are not required to provide notifications in the event of a breach of such information—that is, the information is not considered “unsecured” in such cases. As required by the Act, the Secretary initially issued this guidance on April

17, 2009 (it was subsequently published at 74 FR 19006 on April 27, 2009). The guidance listed and described encryption and destruction as the two technologies and methodologies for rendering protected health information unusable, unreadable, or indecipherable to unauthorized individuals.

In cases in which notification is required, the Act at section 13402 prescribes the timeliness, content, and methods of providing the breach notifications.

Section 13402 required HHS to issue within 180 days of enactment interim final regulations to implement these breach notification requirements. The Department issued an interim final rule on August 24, 2009, with a 60-day public comment period (74 FR 42740). The interim final rule became effective on September 23, 2009. In the preamble to the interim final rule, the Department also re-issued without substantive change its Guidance Specifying the Technologies and Methodologies That Render Protected Health Information Unusable, Unreadable, or Indecipherable to Unauthorized Individuals that was initially issued on April 17, 2009. The Guidance continues to specify encryption and destruction as the two methods for rendering protected health information unusable, unreadable, or indecipherable to unauthorized individuals—or “secured”—and thus, exempt from the breach notification obligations. See 74 FR 42741–43.

B. Overview of the Interim Final Rule

The interim final rule added a new subpart D to part 164 of title 45 of the Code of Federal Regulations (CFR) to implement the breach notification provisions of section 13402 of the HITECH Act. In developing the interim final rule, the Department consulted closely with the Federal Trade Commission (FTC), which administers similar breach notification requirements on vendors of personal health records (PHRs) and their third party service providers under section 13407 of the HITECH Act. The interim final rule and FTC’s Health Breach Notification Rule (74 FR 42962, published August 25, 2009) made clear that entities operating as HIPAA covered entities and business associates are subject to HHS’, and not the FTC’s, breach notification rule. Second, to address those limited cases where an entity may be subject to both HHS’ and the FTC’s rules, such as a vendor that offers PHRs to customers of a HIPAA covered entity as a business associate and also offers PHRs directly to the public, both sets of regulations were harmonized by including the same

or similar language, within the constraints of the statutory language.

The 60-day public comment period on the interim final rule closed on October 23, 2009. The Department received approximately 120 comments during the comment period from a variety of entities, including health care providers, hospital and medical associations, health plans, educational institutions, information technology companies, privacy and security advocates, consumer groups, state agencies, and several members of Congress. The provisions of the interim final rule are discussed in more detail below, along with the public comments received, and the provisions of this final rule.

C. Section-by-Section Description of Final Rule and Response to Comments

1. Section 164.402—Definitions

a. Definition of “Breach”

Interim Final Rule

Section 13400(1)(A) of the Act defines “breach” as the “unauthorized acquisition, access, use, or disclosure of protected health information which compromises the security or privacy of such information, except where an unauthorized person to whom such information is disclosed would not reasonably have been able to retain such information.” Section 13400(1)(B) of the Act provides two additional exceptions to the definition of “breach.” The interim final rule at 45 CFR 164.402 defined a “breach” to mean generally “the acquisition, access, use, or disclosure of protected health information in a manner not permitted [by the Privacy Rule] which compromises the security or privacy of the protected health information.” The definition included the statutory exceptions to the definition (discussed below) and clarified that “unauthorized” for purposes of the statute meant in a manner not permitted by the Privacy Rule.

In addition, for purposes of this definition, the rule provided that “compromises the security or privacy of the protected health information” means poses a significant risk of financial, reputational, or other harm to the individual. The Department included this standard regarding a significant risk of harm to the individual (i.e., harm standard) after considering public comment received in response to the Department’s request for information on the HITECH Act’s breach notification provisions. See 74 FR 19006. The inclusion of the harm standard was intended to align the Department’s rule with many State

breach notification laws, as well as existing obligations on Federal agencies pursuant to OMB Memorandum M–07–16, that have similar standards for triggering breach notification. In addition, the standard was intended to ensure that consumers were not flooded with breach notifications for inconsequential events, which could cause unnecessary anxiety and eventual apathy among consumers.

To determine whether an impermissible use or disclosure of protected health information constitutes a breach under this standard, covered entities and business associates were required to perform a risk assessment to determine if there is a significant risk of harm to the individual as a result of the impermissible use or disclosure. In conducting the risk assessment, covered entities and business associates were to consider a number or combination of factors, including who impermissibly used the information or to whom the information was impermissibly disclosed; whether the covered entity or business associate had taken steps to mitigate or eliminate the risk of harm; whether the protected health information was actually accessed; and what type or amount of protected health information was impermissibly used or disclosed.

The rule provided further that an impermissible use or disclosure of protected health information that qualifies as a limited data set but also excludes dates of birth and zip codes (both identifiers that may otherwise be included in a limited data set) does not compromise the security or privacy of the protected health information. The Department included this narrow exception in the belief that it would be very difficult to re-identify a limited data set that excludes dates of birth and zip codes. Thus, a breach of such information would pose a low level of risk of harm to an individual.

The interim final rule also included the three statutory exceptions to the definition of breach. To implement section 13400(1)(B)(i) of the Act, the first regulatory exception provided that a breach excludes any unintentional acquisition, access, or use of protected health information by a workforce member or person acting under the authority of a covered entity or business associate, if such acquisition, access, or use was made in good faith and within the scope of authority and does not result in further use or disclosure in a manner not permitted by the Privacy Rule. We substituted the term “workforce members” for the statutory term “employees” because “workforce member” is a defined term for purposes

of the HIPAA Rules and means employees, volunteers, trainees, and other persons whose conduct, in the performance of work for a covered entity or business associate, is under the direct control of such covered entity or business associate.

In addition to unintentional, good faith access to protected health information by workforce members, this exception covers similar access by a business associate of a covered entity or subcontractor with respect to a business associate or other person acting on behalf of a covered entity or business associate. The exception does not, however, cover situations involving snooping employees, because access as a result of such snooping would be neither unintentional nor done in good faith.

To implement section 13400(1)(B)(ii) and (iii) of the Act, the second regulatory exception provided that a breach excludes inadvertent disclosures of protected health information from a person who is authorized to access protected health information at a covered entity or business associate to another person authorized to access protected health information at the same covered entity, business associate, or organized health care arrangement in which the covered entity participates. The regulatory exception includes reference to an “organized health care arrangement” to capture, among other things, clinically integrated care settings in which individuals typically receive health care from more than one health care provider, such as a hospital, and the health care providers who have staff privileges at the hospital.

In this regulatory exception, we also interpreted the statutory limitations that the disclosure be to “another person similarly situated at the same facility” to mean that the disclosure be to another person authorized to access protected health information (even if the two persons may not be authorized to access the same types of protected health information) at the same covered entity, business associate, or organized health care arrangement in which the covered entity participates (even if the covered entity, business associate, or organized health care arrangement has multiple facilities or locations across the country).

Finally, to implement section 13400(1)(A) of the Act, the interim final rule exempted disclosures of protected health information where a covered entity or a business associate has a good faith belief that an unauthorized person to whom the disclosure was made would not reasonably have been able to retain such information. For example, if

a covered entity, due to a lack of reasonable safeguards, sends a number of explanations of benefits (EOBs) to the wrong individuals and a few of the EOBs are returned by the post office, unopened, as undeliverable, the covered entity can conclude that the improper addressees could not reasonably have retained the information. The EOBs that were not returned as undeliverable, however, and that the covered entity knows were sent to the wrong individuals, should be treated as potential breaches. As another example, if a nurse mistakenly hands a patient the discharge papers belonging to another patient, but she quickly realizes her mistake and recovers the protected health information from the patient, this would not constitute a breach if the nurse can reasonably conclude that the patient could not have read or otherwise retained the information.

With respect to any of the three exceptions discussed above, a covered entity or business associate has the burden of proof, pursuant to § 164.414(b) (discussed below), for showing why breach notification was not required. Accordingly, the covered entity or business associate must document why the impermissible use or disclosure falls under one of the above exceptions.

Overview of Public Comments

Of the approximately 85 public comments received on the interim final rule addressing the definition of breach, approximately 70 of those comments addressed the harm standard and risk assessment approach in the interim final rule. We received approximately 60 comments in support of the harm standard and the risk assessment approach. The commenters in support of this approach included providers, health plans, professional associations, and certain members of Congress. These commenters argued that the inclusion of the harm standard and accompanying risk assessment was consistent with the statutory language, aligned the interim final rule with many State breach notification laws and Federal policies, and appropriately placed the obligation to determine if a breach had occurred on covered entities and business associates since they had the requisite knowledge of the incident to best assess the likely impact of the impermissible use or disclosure.

The proponents of the harm standard and risk assessment approach also argued that its removal would increase the cost and burden of implementing the rule for covered entities, business associates, as well as HHS, and may cause unnecessary anxiety and eventual

apathy among consumers if notifications are sent when there is no risk of harm to the individual.

We also received approximately 10 comments opposed to the harm standard. Generally, the commenters opposed to this approach were members of Congress and consumer advocacy groups. Some opponents of the harm standard argued that its addition to the interim final rule set too high a bar for triggering breach notification, which was contrary to statutory intent. These commenters argued that the final rule should adopt a bright line standard for breach notification to ensure that individuals are aware of all impermissible uses and disclosures of their health information regardless of the potential risk and to make implementation and enforcement of the rule more uniform by removing the discretion and judgment given to covered entities in the interim final rule. These commenters argued that such transparency would better breed consumer trust and would allow individuals to assess the risk of harm themselves and take necessary measures to mitigate an impermissible use or disclosure of their health information.

Other commenters, while opposed to a harm standard to trigger breach notification, nonetheless agreed that breach notification should not be required following every impermissible use or disclosure of unsecured protected health information no matter how inconsequential the breach. These commenters argued that, rather than a subjective standard measuring the risk of harm to an individual, the final rule should include a more objective standard against which entities would be required to assess risk. These commenters suggested that the risk assessment should focus on the risk that the protected health information was compromised instead of on the risk of harm to the individual. Additionally, these commenters proposed four factors that should be considered to determine whether the information was compromised: (1) To whom the information was impermissibly disclosed; (2) whether the information was actually accessed or viewed; (3) the potential ability of the recipient to identify the subjects of the data; and (4) in cases where the recipient is the disclosing covered entity's business associate or is another covered entity, whether the recipient took appropriate mitigating action.

Some commenters stated that the default function of the rule was unclear. In particular, these commenters questioned whether the rule required notification of a breach unless it is

determined that a significant risk of harm does not exist, or alternatively, required notification only in cases where significant risk of harm can be demonstrated. Other commenters suggested that we include in the definition an express presumption of a breach unless an entity can show otherwise.

Additionally, many commenters responded to the treatment of limited data sets in the interim final rule. Although many commenters expressed support for the assertion that limited data sets that do not contain dates of birth and zip codes do not compromise the security or privacy of protected health information, most of these commenters expressed concern that the interim final rule did not go far enough and should exempt even those limited data sets that contain dates of birth and/or zip codes from the breach notification requirements. These commenters argued that no impermissible use or disclosure of a limited data set should trigger breach notification obligations because without the 16 direct identifiers that the Privacy Rule requires to be stripped from the information, there is minimal risk of harm to the individual. Additionally, commenters indicated it would be costly and burdensome for entities to have to re-identify the information in a limited data set to provide notification and that re-identifying the information could also pose an additional risk of harm to the affected individuals. Finally, other commenters noted that because researchers commonly rely on limited data sets that contain dates of birth and zip codes, researchers would not be able to take advantage of the exception for certain limited data sets in the interim final rule, which may have the effect of deterring research.

In contrast, some commenters expressed concern regarding the inclusion of even the limited exception to the definition of breach for limited data sets that do not include dates of birth and zip codes. These commenters supported requiring entities to perform a risk assessment to determine whether an impermissible use or disclosure of such information compromised the security or privacy of the information, as there may be a risk of re-identification of this information depending on who received the information.

Final Rule

After considering the public comments on the definition, the Department in this final rule amends the definition of "breach" at 45 CFR 164.402. Based on the comments, we

recognize that the language used in the interim final rule and its preamble could be construed and implemented in manners we had not intended.

Accordingly, this final rule modifies and clarifies the definition of breach and the risk assessment approach outlined in the interim final rule.

First, we have added language to the definition of breach to clarify that an impermissible use or disclosure of protected health information is presumed to be a breach unless the covered entity or business associate, as applicable, demonstrates that there is a low probability that the protected health information has been compromised. We recognize that some persons may have interpreted the risk of harm standard in the interim final rule as setting a much higher threshold for breach notification than we intended to set. As a result, we have clarified our position that breach notification is necessary in all situations except those in which the covered entity or business associate, as applicable, demonstrates that there is a low probability that the protected health information has been compromised (or one of the other exceptions to the definition of breach applies). We believe that the express statement of this presumption in the final rule will help ensure that all covered entities and business associates interpret and apply the regulation in a uniform manner and also responds to commenters that indicated the default function of the rule was unclear. This new language is also consistent with § 164.414, which provides that covered entities and business associates have the burden of proof to demonstrate that all notifications were provided or that an impermissible use or disclosure did not constitute a breach (such as by demonstrating through a risk assessment that there was a low probability that the protected health information had been compromised) and must maintain documentation sufficient to meet that burden of proof.

Second, to further ensure that this provision is applied uniformly and objectively by covered entities and business associates, we have removed the harm standard and modified the risk assessment to focus more objectively on the risk that the protected health information has been compromised. Thus, breach notification is not required under the final rule if a covered entity or business associate, as applicable, demonstrates through a risk assessment that there is a low probability that the protected health information has been compromised, rather than demonstrate that there is no significant risk of harm to the individual as was provided under

the interim final rule. The final rule also identifies the more objective factors covered entities and business associates must consider when performing a risk assessment to determine if the protected health information has been compromised and breach notification is necessary.

Although some commenters urged us to implement a bright line standard, requiring notification for all impermissible uses and disclosures without any assessment of risk, we believe that a risk assessment is necessary. The statute acknowledges, by including a specific definition of breach and identifying exceptions to this definition, as well as by providing that an unauthorized acquisition, access, use, or disclosure of protected health information must compromise the security or privacy of such information to be a breach, that there are several situations in which unauthorized acquisition, access, use, or disclosure of protected health information is so inconsequential that it does not warrant notification. In addition to the statutory exceptions that have been included in both the interim final rule and this final rule, there may be other similar situations that do not warrant breach notification. We agree with commenters that providing notification in such cases may cause the individual unnecessary anxiety or even eventual apathy if notifications of these types of incidents are sent routinely. For example, if a covered entity misdirects a fax containing protected health information to the wrong physician practice, and upon receipt, the receiving physician calls the covered entity to say he has received the fax in error and has destroyed it, the covered entity may be able to demonstrate after performing a risk assessment that there is a low risk that the protected health information has been compromised. Although this scenario does not fit into any of the statutory or regulatory exceptions, we believe that, like the exceptions to breach, notification should not be required if the covered entity demonstrates a low probability that the data has been compromised.

Commenters argued that a rule containing a bright line standard for notification would be easier for both the regulated entities to implement and for HHS to enforce. We disagree. Although a rule that required notification following every impermissible use or disclosure may appear easier for covered entities and business associates to implement—as no determination of the risk that the protected health information has been compromised would be required—in effect, a bright

line standard would be extremely burdensome and costly for entities to implement. With no risk assessment following an impermissible use or disclosure, entities may be required to provide many notices each year for incidents that did not compromise the security or privacy of an individual's protected health information.

Although we do not believe a bright line approach to breach notification is appropriate, we do agree with the commenters who expressed concern that the risk assessment focus on “harm to an individual” in the interim final rule was too subjective and would lead to inconsistent interpretations and results across covered entities and business associates. As a result, instead of assessing the risk of harm to the individual, covered entities and business associates must assess the probability that the protected health information has been compromised based on a risk assessment that considers at least the following factors: (1) The nature and extent of the protected health information involved, including the types of identifiers and the likelihood of re-identification; (2) the unauthorized person who used the protected health information or to whom the disclosure was made; (3) whether the protected health information was actually acquired or viewed; and (4) the extent to which the risk to the protected health information has been mitigated. We believe that the use of these factors, which are derived from the factors listed in the interim final rule as well as many of the factors suggested by commenters, will result in a more objective evaluation of the risk to the protected health information and a more uniform application of the rule.

As we have modified and incorporated the factors that must be considered when performing a risk assessment into the regulatory text, covered entities and business associates should examine their policies to ensure that when evaluating the risk of an impermissible use or disclosure they consider all of the required factors. In addition, given the circumstances of the impermissible use or disclosure, additional factors may need to be considered to appropriately assess the risk that the protected health information has been compromised. We note that, although we have included this risk assessment in the final rule, this type of assessment of risk should not be a new or different exercise for covered entities and business associates. Similar assessments of risk that data have been compromised must be performed routinely following security

breaches and to comply with certain State breach notification laws.

The first factor requires covered entities and business associates to evaluate the nature and the extent of the protected health information involved, including the types of identifiers and the likelihood of re-identification of the information. To assess this factor, entities should consider the type of protected health information involved in the impermissible use or disclosure, such as whether the disclosure involved information that is of a more sensitive nature. For example, with respect to financial information, this includes credit card numbers, social security numbers, or other information that increases the risk of identity theft or financial fraud. With respect to clinical information, this may involve considering not only the nature of the services or other information¹¹ but also the amount of detailed clinical information involved (e.g., treatment plan, diagnosis, medication, medical history information, test results). Considering the type of protected health information involved in the impermissible use or disclosure will help entities determine the probability that the protected health information could be used by an unauthorized recipient in a manner adverse to the individual or otherwise used to further the unauthorized recipient's own interests. Additionally, in situations where there are few, if any, direct identifiers in the information impermissibly used or disclosed, entities should determine whether there is a likelihood that the protected health information released could be re-identified based on the context and the ability to link the information with other available information.¹² For example, if a covered entity impermissibly disclosed a list of patient names, addresses, and hospital identification numbers, the protected health information is obviously identifiable, and a risk assessment likely would determine that there is more than a low probability that the information has been compromised, dependent on an assessment of the other factors discussed below. Alternatively, if the covered entity disclosed a list of patient discharge dates and diagnoses, the

¹¹ We caution that many forms of health information, not just information about sexually transmitted diseases or mental health or substance abuse, are sensitive.

¹² Information that has been de-identified in accordance with 45 CFR 164.514(a)–(c) is not protected health information, and thus, any inadvertent or unauthorized use or disclosure of such information is not considered a breach for purposes of this rule.

entity would need to consider whether any of the individuals could be identified based on the specificity of the diagnosis, the size of the community served by the covered entity, or whether the unauthorized recipient of the information may have the ability to combine the information with other available information to re-identify the affected individuals (considering this factor in combination with the second factor discussed below). We emphasize, however, that the entity must evaluate all the factors, including those discussed below, before making a determination about the probability of risk that the protected health information has been compromised.

The second factor requires covered entities and business associates to consider the unauthorized person who impermissibly used the protected health information or to whom the impermissible disclosure was made. Entities should consider whether the unauthorized person who received the information has obligations to protect the privacy and security of the information. For example, as discussed in the interim final rule, if protected health information is impermissibly disclosed to another entity obligated to abide by the HIPAA Privacy and Security Rules or to a Federal agency obligated to comply with the Privacy Act of 1974 and the Federal Information Security Management Act of 2002, there may be a lower probability that the protected health information has been compromised since the recipient of the information is obligated to protect the privacy and security of the information in a similar manner as the disclosing entity. We also emphasize that this factor should be considered in combination with the factor discussed above regarding the risk of re-identification. If the information impermissibly used or disclosed is not immediately identifiable, entities should determine whether the unauthorized person who received the protected health information has the ability to re-identify the information. For example, if information containing dates of health care service and diagnoses of certain employees was impermissibly disclosed to their employer, the employer may be able to determine that the information pertains to specific employees based on other information available to the employer, such as dates of absence from work. In this case, there may be more than a low probability that the protected health information has been compromised.

Several commenters suggested that a risk assessment need be completed following only impermissible

disclosures of protected health information, since information impermissibly “used” remains within the covered entity or business associate. We disagree. The final rule requires a risk assessment to be performed following both impermissible uses and disclosures (that do not otherwise fall within the other enumerated exceptions to breach). However, the fact that information only is impermissibly used within a covered entity or business associate and the impermissible use does not result in further impermissible disclosure outside the entity, is something that may be taken into account in conducting the risk assessment and may reduce the probability that the protected health information has been compromised.

The third factor requires covered entities and business associates to investigate an impermissible use or disclosure to determine if the protected health information was actually acquired or viewed or, alternatively, if only the opportunity existed for the information to be acquired or viewed. For example, as we discussed in the interim final rule, if a laptop computer was stolen and later recovered and a forensic analysis shows that the protected health information on the computer was never accessed, viewed, acquired, transferred, or otherwise compromised, the entity could determine that the information was not actually acquired by an unauthorized individual even though the opportunity existed. In contrast, however, if a covered entity mailed information to the wrong individual who opened the envelope and called the entity to say that she received the information in error, then, in this case, the unauthorized recipient viewed and acquired the information because she opened and read the information to the extent that she recognized it was mailed to her in error.

The final factor included in the final rule requires covered entities and business associates to consider the extent to which the risk to the protected health information has been mitigated. Covered entities and business associates should attempt to mitigate the risks to the protected health information following any impermissible use or disclosure, such as by obtaining the recipient’s satisfactory assurances that the information will not be further used or disclosed (through a confidentiality agreement or similar means) or will be destroyed, and should consider the extent and efficacy of the mitigation when determining the probability that the protected health information has been compromised. We note that this

factor, when considered in combination with the factor regarding the unauthorized recipient of the information discussed above, may lead to different results in terms of the risk to the protected health information. For example, a covered entity may be able to obtain and rely on the assurances of an employee, affiliated entity, business associate, or another covered entity that the entity or person destroyed information it received in error, while such assurances from certain third parties may not be sufficient. As described above, certain commenters suggested that mitigation should only be considered where the recipient of the information is a business associate of the covered entity or another covered entity. We do not in this rule limit this factor to those circumstances but, as discussed above, acknowledge that the recipient of the information will have an impact on whether the covered entity can conclude that an impermissible use or disclosure has been appropriately mitigated.

A covered entity’s or business associate’s analysis of the probability that protected health information has been compromised following an impermissible use or disclosure must address each factor discussed above. Other factors may also be considered where necessary. Covered entities and business associates must then evaluate the overall probability that the protected health information has been compromised by considering all the factors in combination, and we expect these risk assessments to be thorough, completed in good faith, and for the conclusions reached to be reasonable. If an evaluation of the factors discussed above fails to demonstrate that there is a low probability that the protected health information has been compromised, breach notification is required. We do note, however, that a covered entity or business associate has the discretion to provide the required notifications following an impermissible use or disclosure of protected health information without performing a risk assessment. Because the final rule clarifies the presumption that a breach has occurred following every impermissible use or disclosure of protected health information, entities may decide to notify without evaluation of the probability that the protected health information has been compromised. In the future, we will issue additional guidance to aid covered entities and business associates in performing risk assessments with respect to frequently occurring scenarios.

In addition to the removal of the harm standard and the creation of more objective factors to evaluate the probability that protected health information has been compromised, we have removed the exception for limited data sets that do not contain any dates of birth and zip codes. In the final rule, following the impermissible use or disclosure of any limited data set, a covered entity or business associate must perform a risk assessment that evaluates the factors discussed above to determine if breach notification is not required.

The vast majority of commenters were not supportive of the exception for certain limited data sets outlined in the interim final rule, either because they believed the exception did not go far enough and would chill research that needed access to birth dates and zip codes in limited data sets, or because of concerns regarding the re-identifiability of the limited information to which the exception applied. Based on the comments, we believe it is appropriate to require the impermissible use or disclosure of a limited data set, even those that do not contain dates of birth and zip codes, to be subject to a risk assessment to demonstrate that breach notification is not required. The final rule expressly includes a factor that would require consideration of the re-identifiability of the information, as well as a factor that requires an assessment of the unauthorized person who used the protected health information or to whom the disclosure was made (i.e., whether this person has the ability to re-identify the affected individuals). Thus, the factors are particularly suited to address the probability that a data set without direct identifiers has been compromised following an impermissible use or disclosure. Further, we believe in most cases that the result would be the same under this final rule as under the interim final rule with respect to whether an impermissible use or disclosure of a limited data set that also excludes dates of birth and zip codes constitutes a breach for which notification is required. Due to the lack of identifiers present in the protected health information, entities may reasonably determine that there is a low probability of risk that the information has been compromised; however, we stress that this is a fact specific determination to be made based on the circumstances of the impermissible use or disclosure.

We encourage covered entities and business associates to take advantage of the safe harbor provision of the breach notification rule by encrypting limited data sets and other protected health

information pursuant to the Guidance Specifying the Technologies and Methodologies that Render Protected Health Information Unusable, Unreadable, or Indecipherable to Unauthorized Individuals (74 FR 42740, 42742). If protected health information is encrypted pursuant to this guidance, then no breach notification is required following an impermissible use or disclosure of the information.

In addition to the comments discussed above, it was suggested that covered entities be required to include in their notice of privacy practices information about how a risk assessment will be conducted or their internal policies for determining whether a breach has occurred and notification is warranted. It was also suggested that the breach notice to the individual following discovery of a breach of unsecured protected health information contain information about the covered entity or business associate's risk assessment to help the individual better assess the level of threat posed by the breach and to better determine the appropriate steps, if any, to take.

We decline to require that the covered entity's notice of privacy practices include a description of how a risk assessment will be conducted, although covered entities may include such information in their notice of privacy practices if they choose. While each risk assessment will differ depending on the specific facts and circumstances surrounding the impermissible use or disclosure, we believe that the modifications in this final rule will help ensure that covered entities and business associates perform risk assessments more uniformly and objectively. We also note that the content requirements for the notice to the individual outlined in § 164.404(c) already require that the individual be notified of the circumstances of a breach, as well as what steps individuals should take to protect themselves from potential harm resulting from the breach.

One commenter suggested that we require a covered entity to hire an independent organization to assess the risk of an impermissible use or disclosure to determine if breach notification is required. We do not believe such a requirement is necessary, although covered entities are free to engage independent organizations to assist in making such determinations provided that, if access to protected health information is required, business associate agreements are entered into to protect the information. Further, we believe the modifications in this final

rule are conducive to more uniform risk assessments across covered entities and business associates. Additionally, as with the interim final rule, we note that covered entities and business associates have the burden of proof, pursuant to § 164.414, to demonstrate that all notifications were provided or that an impermissible use or disclosure did not constitute a breach and to maintain documentation (e.g., of the risk assessment demonstrating that there was a low probability that the protected health information had been compromised or of the assessment that the impermissible use or disclosure falls within one of the other exceptions to breach), pursuant to 45 CFR 164.530(j)(1)(iv), as necessary to meet this burden of proof. Thus, covered entities and business associates have adequate incentive to conduct reasonable and diligent risk assessments.

Finally, after reviewing and considering the comments received regarding the exceptions to the definition of breach in the interim final rule, the Department adopts these exceptions without modification in this final rule. Although the substance of these exceptions has not changed, these exceptions are now located at paragraph (1) of the definition of breach instead of paragraph (2) to accommodate the modifications discussed above. We respond to the public comments addressing these exceptions, as well as other comments received on the definition of "breach," below.

Response to Other Public Comments

Comment: Many commenters expressed concern that violations of the minimum necessary standard may trigger breach notification obligations.

Response: We do not believe it would be appropriate to exempt minimum necessary violations from the breach notification obligations as we do not believe that all minimum necessary violations present a low probability that the protected health information has been compromised. Thus, uses or disclosures that impermissibly involve more than the minimum necessary information, in violation of §§ 164.502(b) and 164.514(d), may qualify as breaches. Such incidents must be evaluated as any other impermissible uses or disclosures to determine whether breach notification is not required.

As explained above, there are several factors to be considered when determining the probability that the protected health information involved in an impermissible use or disclosure has been compromised, including the

unauthorized person who used the information or to whom the disclosure was made. Thus, where a minimum necessary violation occurs in a disclosure to a business associate or as an internal use within a covered entity or business associate, the fact that the information was not acquired by a third party would be considered as part of the risk assessment and may help lead to the conclusion that there is a low probability that the protected health information has been compromised. Alternatively, covered entities and business associates may determine that certain minimum necessary violations fall within the exceptions to the definition of breach at § 164.402(1)(i) or (1)(ii).

We note that the Privacy Rule's minimum necessary standard requires a covered entity to make reasonable efforts to limit access to protected health information to those persons or classes of persons who need access to protected health information to carry out their duties and to disclose an amount of protected health information reasonably necessary to achieve the purpose of a disclosure. The Privacy Rule requires covered entities to determine and define in their policies and procedures how the minimum necessary standard applies to their own uses and disclosures. Thus, covered entities are in a good position to know when such policies and procedures have been violated and to assess the probability that the incident has compromised the security or privacy of the information. Finally, we will consider including further guidance regarding the interaction between the minimum necessary standard and the breach notification requirements in the guidance required by section 13405(b)(1)(B) of the HITECH Act.

Comment: Several commenters asked that we clarify the differences between "acquisition," "access," "use," and "disclosure" in the exceptions in the final rule. These commenters expressed confusion regarding the use of these terms in the first two exceptions to the definition of breach, stating that the term "acquisition" connotes a disclosure of information, and thus, the exception regarding unintentional acquisition, access, or use of protected health information by a workforce member or person acting under the authority of a covered entity or business associate implicitly includes disclosures of protected health information.

Response: While the Privacy Rule uses the terms "use" and "disclosure," we included both "acquisition" and "access" in the regulatory text for consistency with the statutory language. We interpret "acquisition" and "access"

to information based on their plain meanings and believe that both terms are encompassed within the current definitions of "use" and "disclosure" in the HIPAA Rules. For example, an acquisition may be a "use" or "disclosure" depending on who acquired the information—i.e., a workforce member or someone outside the covered entity, such as a business associate.

Comment: Several commenters supported our interpretations of the statutory terms "employee," "same facility," and "similarly situated individual" with respect to the exceptions to the definition of breach.

Response: We retain these clarifications in this final rule.

Comment: Some commenters asked that we use the term "use" instead of "disclosure" to describe the type of information exchange contemplated by the exception for certain inadvertent disclosures among persons similarly authorized to access protected health information at a covered entity or business associate since the information must be shared within a covered entity or business associate for the exception to apply.

Response: We clarify that the exception at paragraph (1)(ii) of the definition of "breach" is intended to apply to certain "disclosures" that may occur "at" a covered entity, business associate, or organized health care arrangement in which the covered entity participates—e.g., to persons onsite at a covered entity's facility that are not workforce members, such as physicians with staff privileges at a hospital. For impermissible "uses" of protected health information among workforce members of a covered entity or a business associate, a covered entity or business associate should determine whether the exception to breach at paragraph (1)(i) regarding certain unintentional acquisition, access, or use by a workforce member or person acting under the authority of a covered entity or business associate applies.

Comment: One commenter asked if breach notification is required in cases where an impermissible use or disclosure originally qualifies for either of the exceptions to breach at § 164.402(1)(i) or (1)(ii) at the time the incident occurs but later no longer fits within the exception because the protected health information is further used or disclosed in an impermissible manner.

Response: The applicability of an exception to breach must be judged at the time the incident is discovered and evaluated. If an exception to breach is determined to apply such that

notification is not warranted, the inquiry into that breach ends; however, the covered entity or business associate should take appropriate steps to ensure that the information is not further used or disclosed impermissibly. If, sometime after making the determination that the exception applied, the information is impermissibly used or disclosed, the covered entity or business associate should treat that incident as a separate impermissible use or disclosure that warrants evaluation as a breach on its own. As explained more fully below, we treat a breach as having occurred at the time of the impermissible use or disclosure, which in the case of the first two exceptions to breach, is at the time of the "further" impermissible use or disclosure.

Comment: One commenter asked that we broaden the application of the inadvertent disclosure exception to apply to all routine disclosures between covered entities. Other commenters asked that the rule exempt from the breach notification obligations situations in which a covered entity discloses information to a business associate or another covered entity. Commenters noted that because covered entities and business associates are required to protect the privacy of protected health information, there is little risk that even an impermissible disclosure between such entities would compromise the security or privacy of the information.

Response: We do not agree that such situations warrant a blanket exception from the breach notification rules. In appropriate cases, some of these impermissible disclosures among covered entities and covered entities and business associates may fall within the existing exceptions to breach at paragraphs (1)(i) and (ii) of the definition. Otherwise, such disclosures must be evaluated as to the probability that the protected health information has been compromised based on a risk assessment of a number of factors. While the fact that the recipient of an impermissible disclosure is a covered entity or business associate with obligations to protect the privacy and security of protected health information is a consideration with respect to assessing the risk that the protected health information has been compromised, it is not the only factor. For example, a covered entity or business associate must also evaluate the extent to which the risk to the protected health information has been mitigated.

Comment: Several commenters suggested that the exceptions to breach should not apply to situations where

workforce members or employees further use or disclose information they unintentionally or inadvertently acquired, accessed, or used, even if such further use or disclosure is permitted under the Privacy Rule. Additionally, these commenters suggested that the breach exceptions should apply only in cases in which the workforce member or employee has taken appropriate steps to mitigate the unintentional acquisition, access, or use of protected health information, such as by alerting the sender of the misdirected information, if applicable, and returning or destroying it.

Response: We do not believe it is appropriate to prohibit the sharing of protected health information for permissible purposes following an unintentional or inadvertent error by a workforce member or an employee. Doing so would restrict access and disclosure of the protected health information for necessary treatment and other important purposes to the extent the workforce member or employee needed access to the information in the future for authorized purposes, which would adversely affect health care delivery. We believe that the rule strikes an appropriate balance by not allowing workforce member errors to be excepted from the definition of breach in cases where the workforce member takes the information he or she has mistakenly obtained and then misuses it.

With respect to requiring workforce members or employees to take appropriate steps to mitigate their unintentional access to protected health information, we note that the Privacy Rule already requires covered entities to ensure as part of their minimum necessary policies and procedures that workforce members have appropriate access to protected health information. Therefore, covered entities should ensure that workforce members who gain access in an unauthorized manner to protected health information do not continue to have such unauthorized access. This may require having policies which require workforce members to return or destroy the information to which they obtained unauthorized access. Further, covered entities must implement reasonable safeguards to protect against impermissible uses and disclosures, including further impermissible uses and disclosures by a workforce member who has gained unauthorized access to protected health information.

Comment: One commenter asked that we include an exception in the final rule for situations in which a laptop is lost and recovered and a forensic analysis shows that the protected health

information on the computer was not accessed. The commenter stated that because the forensic analysis showed that the information was not compromised, a risk assessment should not be required.

Response: We do not include an explicit exception for this particular scenario. As we explained above, in cases where a lost laptop is recovered, the fact that a forensic analysis of the computer shows that its information was not accessed is a relevant consideration for the risk assessment, and entities in such situations may be able to demonstrate a low probability that the information has been compromised. However, covered entities and business associates still must document their risk assessments in these cases. We also note, as we did in the interim final rule, if a computer is lost or stolen, we do not consider it reasonable to delay breach notification based on the hope that the computer will be recovered.

Comment: Some commenters asked that we create an exception to breach to cover certain routine impermissible disclosures of protected health information. For example, commenters asked that we except from notification disclosures made as a result of the covered entity mailing information to a patient's old address, faxing information to the wrong number, disclosures made as a result of leaving a voice message at the wrong number reminding a patient of an upcoming appointment, or, in situations where patients have identical or similar names, contacting the wrong patient to inform him or her that lab results were ready.

Response: We decline to create such an exception. The ability of a covered entity or business associate to demonstrate that a particular situation poses a low probability that the protected health information was compromised is very fact specific and will depend on an assessment of all of the factors discussed above, such as to whom the information was disclosed, what information was disclosed, and what mitigation has taken place. We also note that, in some cases, some of the situations contemplated by the commenters may fall within an existing exception. For example, if a covered entity mails protected health information about an individual to a wrong address, the impermissible disclosure may fall into the exception at paragraph (1)(iii) of the definition of breach if the information is returned, undelivered and unopened, to the covered entity, such that an unauthorized recipient could not reasonably have retained the

information. If, however, the information was not returned or if the covered entity was informed by the unauthorized recipient that he had received and opened the mail in error, the covered entity would need to complete a risk assessment to determine the probability that the protected health information had been compromised as a result of the impermissible disclosure.

Comment: Several commenters asked that we harmonize the final rule with the FTC's Health Breach Notification final rule.

Response: Although the FTC and HHS breach notification rules generally apply to different entities, HHS has worked closely with the FTC to ensure both sets of regulations were harmonized to the greatest extent possible by including the same or similar requirements within the constraints of the statutory language. In addition, in the few situations where an entity provides PHRs to customers of a HIPAA covered entity through a business associate arrangement but also provides PHRs directly to the public and a breach of its records occurs, in certain cases, the FTC will deem compliance with certain provisions of HHS' rule as compliance with FTC's rule. See 74 FR 42964. In particular, in such situations, it may be appropriate for the vendor to provide the same breach notice to all its PHR customers since it has a direct relationship with all the affected individuals. Thus, in those limited circumstances where a vendor of PHRs (1) provides notice to individuals on behalf of a HIPAA covered entity, (2) has dealt directly with these individuals in managing their PHR accounts, and (3) provides notice to its customers at the same time, the FTC will deem compliance with HHS requirements governing the timing, method, and content of notice to be compliance with the corresponding FTC rule provisions. Note, however, that the PHR vendor still must comply with all other FTC rule requirements, including the requirement to notify the FTC within ten business days after discovering the breach.

b. Definition of "Unsecured Protected Health Information"

Interim Final Rule

Section 13402(h)(1)(A) of the Act defines "unsecured protected health information" as "protected health information" that is not secured through the use of a technology or methodology specified by the Secretary in guidance issued under [section 13402(h)(2)]." The Act at section 13402(h)(2) requires that the Secretary specify in the guidance the technologies and methodologies that

render protected health information unusable, unreadable, or indecipherable to unauthorized individuals. Accordingly, the interim final rule defined “unsecured protected health information” as protected health information that is not rendered unusable, unreadable, or indecipherable to unauthorized individuals through the use of a technology or methodology specified by the Secretary in guidance. This guidance, which was published in updated form within the preamble to the interim final rule and made available on the HHS Web site, specifies that only encryption and destruction, consistent with National Institute of Standards and Technology (NIST) guidelines, renders protected health information unusable, unreadable, or indecipherable to unauthorized individuals such that notification is not required in the event of a breach of such information.

Overview of Public Comments

While we received a number of technical and other comments on the guidance, we did not receive any comments on the language of the above definition itself. We intend to address the comments on the guidance in our next update to the guidance.

Final Rule

The final rule modifies the interim final rule’s definition of “unsecured protected health information” to replace the term “unauthorized individuals” in the definition with “unauthorized persons.” The term “individual” is defined in § 160.103 to mean the person who is the subject of the protected health information, which is not what is intended with the reference to “individual” in the definition of “unsecured protected health information.” Accordingly, the final rule uses more appropriately the term “unauthorized persons.” The final rule also modifies the definition to remove the term “on the HHS Web site” as unnecessary language. While we remove the reference to the HHS Web site from the regulatory text, we do plan to continue to post updates to the guidance on the Web site as they are issued.

2. Section 164.404—Notification to Individuals

Interim Final Rule

Section 13402(a) of the Act provides that a covered entity that accesses, maintains, retains, modifies, records, stores, destroys, or otherwise holds, uses, or discloses unsecured protected health information shall, in the case of a breach of such information that is discovered by the covered entity, notify

each affected individual whose unsecured protected health information has been, or is reasonably believed by the covered entity to have been, accessed, acquired, or disclosed as a result of such breach. Accordingly, § 164.404(a)(1) of the interim final rule included the general rule that a covered entity shall, following the discovery of a breach of unsecured protected health information, notify each individual whose unsecured protected health information has been, or is reasonably believed to have been accessed, acquired, used, or disclosed as a result of such breach.

Breaches Treated as Discovered

Section 13402(c) of the HITECH Act states that a breach shall be treated as discovered by a covered entity or business associate as of the first day on which such breach is known or should reasonably have been known to the covered entity or business associate. The Act also specifies that this discovery is triggered as soon as any person, other than the individual committing the breach, who is an employee, officer, or other agent of the covered entity or business associate knows or should reasonably have known of the breach.

Section 164.404(a)(2) of the interim final rule implemented the Act’s discovery provision, with respect to covered entities by stating that a breach shall be treated as discovered by a covered entity on the first day the breach is known to the covered entity, or by exercising reasonable diligence would have been known to the covered entity. The interim final rule incorporated the term “by exercising reasonable diligence,” which is used in the HIPAA Enforcement Rule and defined to mean the “business care and prudence expected from a person seeking to satisfy a legal requirement under similar circumstances.”

Section 164.404(a)(2) of the interim final rule further provided, in accordance with the Act, that a covered entity is deemed to have knowledge of a breach if such breach is known, or by exercising reasonable diligence would have been known, to any person other than the person committing the breach, who is a workforce member or agent of the covered entity. Thus, the breach is treated as discovered by the covered entity at the time the workforce member or other agent has knowledge of the breach. The rule also clarified that the federal common law of agency controls in determining who is an agent of the covered entity, which is consistent with how agency liability is determined under the HIPAA Rules.

Overview of Public Comments

Several commenters argued that a breach should be treated as discovered by a covered entity only after management has been notified of the incident. Commenters stated that the Department should not hold an entity responsible for knowing of a breach if an appropriately trained employee fails to inform the proper persons within the entity of a breach. Other commenters asked for guidance and more clarification regarding what it means for a covered entity or business associate to be exercising reasonable diligence, such as what frequency of monitoring for breaches is expected or what types of systems must covered entities and business associates have in place to detect breaches.

Final Rule

We retain § 164.404(a)(2) in this final rule without modification. We decline to adopt the suggestion that a covered entity be deemed to have discovered a breach only when management is notified of the breach. The HITECH Act itself provides that a breach is to be treated as discovered by a covered entity or business associate if “any person, other than the individual committing the breach, that is an employee, officer, or other agent of such entity or associate” knows or should reasonably have known of the breach. This concept is also consistent with the HIPAA Enforcement Rule and the Federal common law of agency. We encourage covered entities and business associates to ensure their workforce members and other agents are adequately trained on the importance of prompt reporting of privacy and security incidents.

With respect to those commenters asking for guidance on what it means for a covered entity to be exercising reasonable diligence, we note that the term reasonable diligence, as defined in § 160.401, means the business care and prudence expected from a person seeking to satisfy a legal requirement under similar circumstances. The determination of whether a person acted with reasonable diligence is generally a factual one, since what is reasonable depends on the circumstances. Factors to be considered include whether a covered entity or business associate took reasonable steps to learn of breaches and whether there were indications of breaches that a person seeking to satisfy the Rule would have investigated under similar circumstances. Covered entities and business associates may wish to look to how other covered entities and business associates operating under

whether the breach involved more than 500 residents of a particular State or jurisdiction (the threshold for triggering notification to the media under § 164.406 of the interim final rule). Thus, where a covered entity has discovered a breach involving 600 individuals, 300 of which reside in Maryland and 300 of which reside in the District of Columbia, notification of the breach must be provided to the Secretary concurrently with notification to the affected individuals. However, in this example, the breach would not trigger the requirement to notify the media under § 164.406 because the breach did not involve more than 500 residents of any one State or jurisdiction.

For breaches involving less than 500 individuals, § 164.408(c) requires a covered entity to maintain a log or other documentation of such breaches and to submit information annually to the Secretary for breaches occurring during the preceding calendar year. The interim final rule required the submission of this information to the Secretary no later than 60 days after the end of each calendar year. As with notification of the larger breaches, the interim final rule required that information about breaches involving less than 500 individuals be provided to the Secretary in the manner specified on the HHS Web site.

Although covered entities need only provide notification to the Secretary of breaches involving less than 500 individuals annually, they must still provide notification of such breaches to affected individuals without unreasonable delay and not later than 60 days after discovery of the breach pursuant to § 164.404. In addition, pursuant to § 164.414(a), a covered entity must follow the documentation requirements that otherwise apply to the HIPAA Privacy Rule under § 164.530 with respect to the requirements of this rule. Thus, pursuant to § 164.530(j)(2), covered entities must maintain the internal log or other documentation for six years. Further, as with other required documentation, a covered entity must make such information available to the Secretary upon request for compliance and enforcement purposes in accordance with § 160.310.

Overview of Public Comments

Some commenters expressed concern regarding the timing of providing notification to the Secretary of breaches affecting fewer than 500 individuals. These commenters asked when notification should be provided if a covered entity discovers, after the reporting deadline, a breach that

occurred in the previous year. Several others commented on the interim final rule's process for providing the Secretary with breach notification. Some commenters asked that this process be revised to allow covered entities to maintain a log of all breaches affecting fewer than 500 individuals and then submit that log, via attachment (such as an Excel spreadsheet), to the Secretary on an annual basis. These commenters stated that submitting reports of these smaller breaches in this manner would be much less burdensome than submitting the reports individually. Other commenters asked that we provide a template log for entities to use to document smaller breaches for annual submission to the Secretary. Additionally, several commenters suggested that there be access or authentication controls for submitting breach reports because of concerns of false breach reports being submitted to the Secretary without the covered entity's knowledge.

Final Rule

The final rule retains § 164.408(c) with one modification. The modification clarifies that covered entities are required to notify the Secretary of all breaches of unsecured protected health information affecting fewer than 500 individuals not later than 60 days after the end of the calendar year in which the breaches were "discovered," not in which the breaches "occurred." We recognize that there may be situations where, despite having reasonable and appropriate breach detection systems in place, a breach may go undetected for some time. In these cases, if a breach of unsecured protected health information affecting fewer than 500 individuals that occurred in the previous year is discovered, the covered entity has until 60 days after the end of the calendar year in which the breach was discovered to provide notice to the Secretary. We emphasize, however, that this modification does not alter a covered entity's obligation to promptly report the breach to affected individuals without unreasonable delay but in no cases later than 60 calendar days after discovery of the breach.

In response to the comments suggesting that covered entities be permitted to submit a log of all smaller breaches to the Secretary instead of submitting each breach individually through the online form, we agree that the current process may be burdensome for some entities and are considering alternative ways to receive such reports.

With respect to the commenters who asked that access or authentication

controls be added to the breach reporting form, we do not believe this is necessary at the present time. Since the Department began receiving and processing breach reports on September 23, 2009, we have not yet received a report that has been falsely submitted by an individual or entity not acting on behalf of the covered entity. Additionally, we emphasize that following receipt of a breach report that affects 500 or more individuals, we contact the covered entity identified in the breach report and verify the information in the report before we post any information about the breach on the HHS Web site. If circumstances change in the future, we will explore options for modifying the process.

Response to Other Public Comments

Comment: One commenter asked that the final rule should not interpret the term "immediately" in the statute to mean without unreasonable delay, but in no case later than 60 days, but rather to mean as soon as the breach is discovered. Another commenter asked that the final rule expand the timeframe for providing notification to the Secretary to no later than 120 days after discovery of a breach.

Response: We believe that our interpretation of "immediately" with respect to notification to the Secretary for breaches affecting 500 or more individuals is reasonable and appropriate and thus, retain the provision that requires such notice be provided contemporaneously with notice to the individual. Requiring contemporaneous notice allows the notice to the Secretary to include all of the information provided in the notice to the individual and better ensures that a covered entity does not report information to the Secretary that later turns out to be incorrect because the entity did not have sufficient time to conduct an investigation into the facts surrounding the breach. In addition, this interpretation satisfies the statutory requirement that notifications of larger breaches be provided to the Secretary immediately (as they occur) as compared to the reports of smaller breaches the statute allows be reported annually to the Secretary.

Comment: Some commenters asked for further guidance on submitting online breach notifications to the Secretary. Additionally, some commenters asked that HHS provide a confirmation to submitters that an initial breach report or an addendum to a breach report has been successfully submitted.

Response: Since the publication of the interim final rule, OCR has posted

instructions for filling out and submitting the breach form on its Web site: <http://www.hhs.gov/ocr/privacy/hipaa/administrative/breachnotificationrule/brinstruction.html>. We will continue to examine the instructions for submitting breach notification to the Secretary and will update this information, as necessary, to ensure that covered entities are able to navigate and submit the form easily. The Department has also made changes to the process to ensure that covered entities receive a confirmation following their submission of breach notification to the Secretary. Additionally, we note that the breach reporting form does include an option for indicating that a submission is an addendum to a previous submission. OCR updates the original breach report, as appropriate, with any additional or modified information submitted in an addendum.

Comment: With respect to the posting of breaches affecting 500 or more individuals on the HHS Web site, some commenters stated that these breach submissions must be verified with the covered entity before they are posted publicly. Other commenters asked for clarification of what information will be posted, while another commenter asked that we post only the name of the covered entity involved in the breach. Finally, one commenter suggested that we only post these breaches on our Web site for a six month period.

Response: To provide helpful information to the public, OCR currently posts the following information regarding breaches affecting 500 or more individuals: name of the covered entity (and if applicable, the business associate) involved; State where the covered entity is located; number of individuals affected by the breach; the date of the breach; type of breach (e.g., theft, loss, unauthorized access/disclosure); and location of the breached information (e.g., laptop, paper records, desktop computer). Prior to posting this information, OCR verifies the information in the breach notification report with the covered entity. We do not believe it would serve the public to only disclose the name of the covered entity involved in each of the breaches, because the additional information enables members of the public to understand the nature of the breach and to determine if the breach affects them directly. In terms of how long information about each of the breaches is to remain posted, we intend to maintain the information on our Web site for as long as there is public interest and the data can remain posted in a

manner that gives the public access effectively and efficiently.

5. Section 164.410—Notification by a Business Associate Interim Final Rule

Section 13402(b) of the HITECH Act requires a business associate of a covered entity that accesses, maintains, retains, modifies, records, destroys, or otherwise holds, uses, or discloses unsecured protected health information to notify the covered entity when it discovers a breach of such information. The Act requires business associates to provide such notification to covered entities without unreasonable delay and in no case later than 60 days from discovery of the breach. Additionally, the Act requires business associates to provide covered entities with the identity of each individual whose unsecured protected health information has, or is reasonably believed to have been, affected by the breach. Section 164.410(a) implements section 13402(b) of the Act.

A business associate is required to notify the covered entity of the breach of unsecured protected health information so that the covered entity can notify affected individuals. In the interim final rule, we clarified that a business associate that maintains the protected health information of multiple covered entities need notify only the covered entity(s) to which the breached information relates. However, in cases in which a breach involves the unsecured protected health information of multiple covered entities and it is unclear to whom the breached information relates, it may be necessary to notify all potentially affected covered entities.

Section 164.410(a)(2) provides that a breach shall be treated as discovered by a business associate as of the first day on which such breach is known to the business associate or, by exercising reasonable diligence, would have been known to the business associate. As with a covered entity, a business associate shall be deemed to have knowledge of a breach if the breach is known, or by exercising reasonable diligence would have been known, to any person, other than the person committing the breach, who is an employee, officer, or other agent of the business associate (determined in accordance with the Federal common law of agency). Similarly, as with knowledge imputed to covered entities, the Federal common law of agency controls in determining who is an agent of the business associate.

Section 164.410(b) requires that a business associate provide notice of a breach of unsecured protected health information to a covered entity without unreasonable delay and in no case later than 60 days following the discovery of a breach. With respect to timing, if a business associate is acting as an agent of a covered entity, then, pursuant to § 164.404(a)(2), the business associate's discovery of the breach will be imputed to the covered entity. In such circumstances, the covered entity must provide notifications under § 164.404(a) based on the time the business associate discovers the breach, not from the time the business associate notifies the covered entity. In contrast, if the business associate is not an agent of the covered entity, then the covered entity is required to provide notification based on the time the business associate notifies the covered entity of the breach. We encouraged covered entities and business associates to address the timing of this notification in their business associate contracts.

Section 164.410(c)(1) requires business associates, to the extent possible, to provide covered entities with the identity of each individual whose unsecured protected health information has been, or is reasonably believed to have been, breached. Depending on the circumstances, business associates could provide the covered entity with immediate notification of the breach and then follow up with the required information in § 164.410(c) when available but without unreasonable delay and within 60 days.

Section 164.410(c)(1) requires business associates to provide this information "to the extent possible," recognizing that there may be situations in which a business associate may be unaware of the identification of the individuals whose unsecured protected health information was breached. For example, a business associate that is a record storage company that holds hundreds of boxes of paper medical records on behalf of a covered entity may be unaware of the names of the individuals whose records are stored. Thus, if the business associate discovers that several boxes are missing, it may be unable to provide the covered entity with a list of the individuals whose information has been breached. In such circumstances, it is not our intent that the business associate delay notification of the breach to the covered entity, when the covered entity may be better able to identify the individuals affected.

Depending on the circumstances surrounding a breach of unsecured protected health information, a business

associate may be in the best position to gather the information the covered entity is required by § 164.404(c) to include in the notification to the individual about the breach. Therefore, in addition to the identification of affected individuals, § 164.410(c)(2) requires a business associate to provide the covered entity with any other available information that the covered entity is required to include in the notification to the individual under § 164.404(c), either at the time it provides notice to the covered entity of the breach or promptly thereafter as information becomes available. Because we allow this information to be provided to a covered entity after the initial notification of the breach as it becomes available, a business associate should not delay the initial notification to the covered entity of the breach in order to collect information needed for the notification to the individual. To ensure the covered entity is aware of all the available facts surrounding a breach, the Rule also requires that a business associate provide this information even if it becomes available after notifications have been sent to affected individuals or after the 60-day period specified in § 164.410(b) has elapsed.

We clarified that business associates and covered entities would continue to have the flexibility to set forth specific obligations for each party, such as who will provide notice to individuals and when the notification from the business associate to the covered entity will be required, following a breach of unsecured protected health information, so long as all required notifications are provided and the other requirements of the interim final rule were met. We encouraged the parties to consider which entity is in the best position to provide notice to the individual, which may depend on circumstances, such as the functions the business associate performs on behalf of the covered entity and which entity has the relationship with the individual. We also encouraged the parties to ensure the individual does not receive notifications from both the covered entity and the business associate about the same breach, which may be confusing to the individual.

Overview of Public Comments

Many commenters expressed concern over the interim final rule's treatment of a covered entity's knowledge of a breach that occurs at or by a business associate. Some commenters stated that a covered entity's knowledge of a breach should begin when the business associate notifies them of the breach, regardless of whether the business associate is an agent of the covered entity or a non-

agent independent contractor. If knowledge is imputed when the business associate discovers the breach, one commenter argued that a covered entity would not have sufficient time to provide the required notifications to individuals in a timely manner. Other commenters argued that all business associates should be treated as agents of the covered entity, such that the business associate's knowledge of a breach is imputed to the covered entity. Finally, some commenters asked for more guidance on when a business associate is acting as an agent versus as an independent contractor and how to determine this status under the Federal common law of agency.

Final Rule

The final rule modifies § 164.410 only to make the following technical and non-substantive correction: in paragraph (a)(2) of § 164.410, the first sentence is revised to refer to paragraph (a)(1) rather than paragraph (1).

With respect to the commenters who expressed concern that a covered entity's knowledge of a breach depends not only on a business associate's discovery of the breach but also on the covered entity's relationship with the business associate, we acknowledge that there are many different types of relationships that can develop between covered entities and business associates based upon the function the business associate performs on behalf of the covered entity. In some situations, a business associate will be acting as an agent of the covered entity, and as such, it makes sense to treat the business associate's knowledge of a breach analogous to the knowledge of one of the covered entity's own employees. However, in other situations, because a business associate may not be an agent of the covered entity, it would not be reasonable to impute the business associate's knowledge directly to the covered entity, and therefore, the covered entity's knowledge depends on notification from the business associate.

Furthermore, the use of the Federal common law of agency to determine the business associate's status with respect to the covered entity is consistent with the approach taken in the Enforcement Rule for determining agency liability under the HIPAA Rules. Thus, we believe the use of the standard is appropriate here and should be familiar to most entities. We provide additional guidance regarding who is an agent above in our response to comments on the HITECH modifications to the HIPAA Enforcement Rule. Because of the agency implications on the timing of breach notifications, we encourage

covered entities to discuss and define in their business associate agreements the requirements regarding how, when, and to whom a business associate should notify the covered entity of a potential breach.

Response to Other Public Comments

Comment: Several commenters asked OCR to provide sample business associate agreement language to outline the covered entity's and business associate's obligations following a breach of unsecured protected health information.

Response: A covered entity's and business associate's obligations following a breach of unsecured protected health information will vary depending on the relationship. For example, whether a business associate will send the breach notices to affected individuals and/or to notify the Secretary (and media, if applicable) on behalf of a covered entity is a business decision of the parties and how quickly a business associate is to notify a covered entity of a breach within the required timeframe may be based on a number of factors, such as whether the business associate is an agent of the covered entity. However, to help covered entities and business associates implement the new business associate agreement requirements generally under the HITECH modifications to the HIPAA Rules, the Department has published sample business associate agreement provisions on its web site.

Comment: Some commenters asked what happens if a covered entity and a business associate disagree about whether an impermissible use or disclosure is a breach that requires notification. These commenters asked if both parties must be in agreement before breach notification obligations are triggered.

Response: The covered entity is ultimately responsible for providing individuals with notification of breaches and, as indicated above, the clock for notifying individuals of breaches begins upon knowledge of the incident, even if it is not yet clear whether the incident qualifies as a breach for purposes of this rule. Further, this final rule clarifies that the default presumption is that an impermissible use or disclosure is a breach unless it can be determined through a risk assessment that there is a low probability that the data may be compromised. This standard should allow for more uniform application of the risk assessment approach across covered entities and business associates.

Comment: One commenter stated that the requirement that a business

associate notify a covered entity of a breach of unsecured protected health information is duplicative of a business associate's other obligations to notify the covered entity of privacy violations and security incidents.

Response: Business associates are required to report to covered entities any security incidents or uses or disclosures of protected health information not provided for by their business associate agreements, which include but are broader than breaches of unsecured protected health information under this Rule. For example, a security incident need not lead to unauthorized access to protected health information (and thus, is not a breach) but is still an event that should be reported to the covered entity. Further, when a security incident occurs that does rise to the level of a breach, the breach notice to the covered entity suffices to meet the requirement to report the security incident to the covered entity (however, a covered entity may require through the business associate agreement that additional information be reported). Therefore, these requirements are not duplicative.

6. Law Enforcement Delay Interim Final Rule

Section 13402(g) of the HITECH Act provides that if a law enforcement official determines that a notification, notice, or posting required under this section would impede a criminal investigation or cause damage to national security, such notification, notice, or posting shall be delayed in the same manner as provided under 45 CFR 164.528(a)(2) of the Privacy Rule in the case of a disclosure covered under such section. Section 164.412 implements section 13402(g) of the Act, requiring a covered entity or business associate to temporarily delay notification to the individual, the media (if applicable), to a covered entity by a business associate, and to the Secretary if instructed to do so by a law enforcement official.

Section 164.412(a), based on the requirements of 45 CFR 164.528(a)(2)(i) of the Privacy Rule, provides for a temporary delay of notification in situations in which a law enforcement official provides a statement in writing that the delay is necessary because notification would impede a criminal investigation or cause damage to national security, and specifies the time for which a delay is required. In such instances, the covered entity is required to delay the notification, notice, or posting for the time period specified by the official.

Similarly, § 164.412(b), based on 45 CFR 164.528(a)(2)(ii) of the Privacy Rule, requires a covered entity or business associate to temporarily delay a notification, notice, or posting if a law enforcement official states orally that a notification would impede a criminal investigation or cause damage to national security. However, in this case, the covered entity or business associate must document the statement and the identity of the official and delay notification for no longer than 30 days, unless a written statement meeting the above requirements is provided during that time. We interpreted these provisions as tolling the time within which notification is required under §§ 164.404, 164.406, 164.408, and 164.410, as applicable.

Final Rule

The Department did not receive public comments on this provision of the interim final rule. We retain § 164.412 in this final rule without modification.

7. Section 164.414—Administrative Requirements and Burden of Proof Interim Final Rule

Section 164.414(a) requires covered entities to comply with the administrative requirements of § 164.530(b), (d), (e), (g), (h), (i), and (j) of the Privacy Rule with respect to the breach notification provisions of this subpart. These Privacy Rule provisions, for example, require covered entities and business associates to develop and document policies and procedures, train workforce members on and have sanctions for failure to comply with these policies and procedures, permit individuals to file complaints regarding these policies and procedures or a failure to comply with them, and require covered entities to refrain from intimidating or retaliatory acts. Thus, a covered entity is required to consider and incorporate the breach notification requirements with respect to its administrative compliance and other obligations.

Section 164.414(b) provides that, following an impermissible use or disclosure under the Privacy Rule, covered entities and business associates have the burden of demonstrating that all notifications were made as required by this subpart. Additionally, as part of demonstrating that all required notifications were made, a covered entity or business associate, as applicable, also must be able to demonstrate that an impermissible use or disclosure did not constitute a breach, as such term is defined at

§ 164.402, in cases where the covered entity or business associate determined that notifications were not required. To conform to these provisions, § 160.534 of the HIPAA Enforcement Rule makes clear that, during any administrative hearing, the covered entity has the burden of going forward and the burden of persuasion with respect to these issues.

Thus, when a covered entity or business associate knows of an impermissible use or disclosure of protected health information, it should maintain documentation that all required notifications were made, or, alternatively, to demonstrate that notification was not required: (1) Its risk assessment (discussed above in § 164.402) demonstrating a low probability that the protected health information has been compromised by the impermissible use or disclosure or (2) the application of any other exceptions to the definition of “breach.”

Overview of Public Comments

One commenter stated that it is critical that all employees are trained and knowledgeable about what constitutes a breach, so that the covered entity or business associate can provide the required notifications within the required timeframe. The commenter also maintained that OCR should emphasize the necessity of this training.

With respect to the burden of proof placed upon covered entities and business associates, one commenter agreed that covered entities and business associates should have the burden to demonstrate that all notifications were provided following a breach of unsecured protected health information. However, the commenter asked that we include a presumption that an impermissible use or disclosure of protected health information did not constitute a breach if a covered entity or business associate has implemented a breach notification policy, completed a risk assessment, and documented that it followed its policy in reaching a conclusion that breach notification was not required.

Final Rule

We retain § 164.414 in this final rule without modification. We emphasize the importance of ensuring that all workforce members are appropriately trained and knowledgeable about what constitutes a breach and on the policies and procedures for reporting, analyzing, and documenting a possible breach of unsecured protected health information. We note that because this final rule modifies the definition of breach as stated in the interim final rule, covered

entities will need to update their policies and procedures and retrain workforce members as necessary to reflect such modifications.

With respect to this burden of proof, section 13402 of the statute places the burden of proof on a covered entity or business associate, if applicable, to demonstrate that all notifications were made as required. Therefore, section 164.530(j)(1)(iv) requires covered entities to maintain documentation to meet this burden of proof. This includes documentation that all required notifications have been provided or that no breach occurred and notification was not necessary. If a covered entity's determination with respect to whether a breach occurred is called into question, the covered entity should produce the documentation that demonstrates the reasonableness of its conclusions based on the findings of its risk assessment.

8. Technical Corrections

The interim final rule made several technical changes to align the HIPAA Rules in light of the new breach notification requirements of subpart D. See 74 FR 42755–56. We did not receive comments on these changes. We retain the technical corrections made in the interim final rule and also make an additional technical correction by adding “and” to the end of § 160.534(b)(1)(iii) to make clear the relationship between § 160.534(b)(1)(iii) and the new § 160.534(b)(1)(iv).

9. Preemption

Interim Final Rule

The interim final rule clarified that contrary State law will be preempted by these breach notification regulations. Section 1178 of the Social Security Act, 42 U.S.C. 1320d–7, which was added by HIPAA, provides that HIPAA administrative simplification provisions generally preempt conflicting State law. Section 160.203 states that a standard, requirement, or implementation specification that is adopted as regulation at 45 CFR parts 160, 162, or 164 and that is “contrary to a provision of State law preempts the provision of State law.” Thus, whether a State law is contrary to these breach notification regulations is to be determined based on the definition of “contrary” at § 160.202, which states that a State law is contrary if “[a] covered entity would find it impossible to comply with both the State and Federal requirements” or if the State law “stands as an obstacle to the accomplishment and execution of the full purposes and objectives” of the breach notification provisions in the Act. Covered entities must analyze

relevant State laws with respect to the breach requirements to understand the interaction and apply this preemption standard appropriately.

In the interim final rule, we stated our belief that, in general, covered entities can comply with both the applicable State laws and this regulation and that in most cases, a single notification can satisfy the notification requirements under State laws and this regulation. For example, if a State breach notification law requires notification be sent to the individual in a shorter time frame than is required by this regulation, a covered entity that sends the notice within the time frame required by the State law will also be in compliance with this regulation's timeliness requirements.

Additionally, since the Act and rule are flexible in terms of how the elements are to be described, and do not prohibit additional elements from being included in the notice, in general, Federal requirements contain flexibility for covered entities to develop a notice that satisfies both laws.

Overview of Public Comments

While some commenters were pleased that the breach notification rule preempts conflicting State law, other commenters expressed confusion or concern with this preemption standard. Many commenters stated that despite the fact that in most cases a covered entity may only need to provide one notification to satisfy both State and Federal law, there will be some cases in which a covered entity will have to provide multiple notices to the same individual to ensure compliance with all relevant laws. This will result in confusion for the individual and increased costs for the covered entity. Some of these commenters suggested that this Federal breach notification law should preempt all State breach notification laws, or alternatively, that HHS should work with Congress and the States to harmonize the breach notification laws such that only one notice is required following a breach.

Final Rule

We maintain the preemption standard discussed in the interim final rule, which is based on section 1128 of the Social Security Act and applies to the HITECH Act's breach notification provisions by virtue of section 13421 of the HITECH Act. We continue to believe that, generally, covered entities are able to comply with both State and Federal requirements for providing breach notification with one breach notice based on the flexibility provided to entities in this Rule. However, even in

the exceptional case, we do not have authority to preempt a State breach notification law that is not contrary to this Rule.

10. Responses to Other Public Comments

Comment: One commenter asked whether penalties are automatically assessed following a violation of the breach notification rule or if this is done at OCR's discretion and whether civil money penalties can be assessed for the underlying cause of a breach of unsecured protected health information where a covered entity has provided all required breach notifications.

Response: OCR's enforcement of the breach notification rule will be carried out pursuant to the Enforcement Rule. Pursuant to the Enforcement Rule, OCR may impose a civil money penalty for a failure to comply with the breach notification rule. OCR also has the discretion to work with the covered entity to achieve voluntary compliance through informal resolution, except in cases in which it has found a violation due to willful neglect. Because every breach of unsecured protected health information must have an underlying impermissible use or disclosure under the Privacy Rule, OCR also has the authority to impose a civil money penalty for the underlying Privacy Rule violation, even in cases where all required breach notifications were provided.

VI. Modifications to the HIPAA Privacy Rule Under GINA

A. Background

The Genetic Information Nondiscrimination Act of 2008 (“GINA”), Public Law 110–233, 122 Stat. 881, prohibits discrimination based on an individual's genetic information in both the health coverage and employment contexts. With respect to health coverage, Title I of GINA generally prohibits discrimination in premiums or contributions for group coverage based on genetic information, proscribes the use of genetic information as a basis for determining eligibility or setting premiums in the individual and Medicare supplemental (Medigap) insurance markets, and limits the ability of group health plans, health insurance issuers, and Medigap issuers to collect genetic information or to request or require that individuals undergo genetic testing. Title II of GINA generally prohibits use of genetic information in the employment context, restricts employers and other entities covered by Title II from requesting, requiring, or purchasing genetic